

Propuesta de Arquitectura de Integración para Modernización Bancaria

Autor: Guillermo Alexis Barcia

Documento técnico para ejercicio práctico de arquitectura de integración.

Objetivo	Disenar una arquitectura de integracion robusta, segura y escalable para modernizar capacidades digitales bancarias.
Sistemas a integrar	Core tradicional, core digital, banca web/movil, plataforma de pagos, APIs Open Finance, riesgos y fraude.
Enfoque	Arquitectura orientada a eventos, estandar BIAN, APIs gobernadas, microservicios y despliegue activo-activo multiregion.
Alcance C4	Contexto, Contenedores y Componentes (dominio de integracion).

Supuestos y restricciones de diseño

- Se prioriza baja latencia en canales digitales y APIs de terceros.
- La arquitectura debe soportar alta disponibilidad (HA), recuperación ante desastres (DR), seguridad y monitoreo end-to-end.
- Se permite uso de servicios cloud en AWS/Azure, incluyendo API Manager y capacidades de observabilidad.
- La integración debe contemplar eventos de negocio y contratos versionados.

1. Arquitectura de alto nivel (incluye BIAN)

La propuesta separa canales, capa de exposición API, dominio de integración y sistemas core/externos. Se adopta una capa de microservicios de integración alineada a dominios BIAN (por ejemplo: Customer Offer, Current Account, Payment Execution, Fraud, Risk). Cada dominio publica eventos de negocio y consume eventos relevantes para desacoplar procesos, habilitar escalabilidad y reducir acoplamiento con legacy.

- Canales (web/movil/partners) consumen APIs en API Gateway con políticas centralizadas.
- Microservicios de integración implementan reglas de orquestación y modelo canónico.
- Adaptadores encapsulan protocolos legacy (API, batch, colas) y protegen al dominio digital de cambios en sistemas heredados.
- Event Bus habilita integración asíncrona, resiliencia operativa y trazabilidad de negocio.

2. Patrones de integración y tecnologías

- **API Gateway Pattern:** unifica seguridad, throttling, versionado y observabilidad.
- **Backend for Frontend (BFF):** optimiza payloads y latencia por canal.
- **Hexagonal Architecture:** separa dominio de integración de infraestructura.
- **Saga Orchestration:** coordina procesos distribuidos con compensaciones.
- **Event-Driven Architecture:** usa publish/subscribe para procesos de pagos, alertas y fraude.
- **Idempotency + Outbox:** evita duplicidad y asegura entrega consistente de eventos.

Stack sugerido: Kubernetes, API Manager (Kong/Apigee/Azure API Management), Kafka/Pulsar, Redis, OpenTelemetry, SIEM, Vault/KMS, IAM corporativo con OAuth2/OIDC y mTLS para B2B.

3. Seguridad, cumplimiento y protección de datos

- **Identidad y acceso:** SSO, OAuth2/OIDC, MFA para canales críticos, autorización ABAC/RBAC por alcance de API.
- **Protección de datos:** cifrado TLS 1.2+ en tránsito y AES-256 en reposo, tokenización de datos sensibles, minimización de PII.
- **Privacidad y ley de datos:** consentimiento explícito, trazabilidad de uso de datos, retención y borrado según normativa local.
- **Seguridad de APIs:** mTLS para terceros, validación de JWT, rate limit por cliente, WAF, detección de anomalías.
- **Cumplimiento:** auditoría inmutable, segregación de funciones, evidencias para auditoría interna y regulador.
- **DevSecOps:** SAST/DAST, escaneo de imágenes, políticas OPA, firma de artefactos, hardening de runtime.

4. Estrategia HA y recuperación ante desastres (DR)

- Despliegue activo-activo en dos regiones con balanceo global y failover automático.
- Microservicios stateless con autoscaling horizontal y probes de salud.
- Kafka/Pulsar con replicación interregion y políticas de retención alineadas al negocio.
- Bases de datos con replica sincrónica para datos críticos y asincrónica para analítica.
- Runbooks de DR probados trimestralmente mediante simulacros de corte regional.

SLO sugeridos: disponibilidad 99.95% para canales digitales, RTO $\leq$ 30 min para procesos críticos, RPO $\leq$ 5 min para transacciones core.

5. Estrategia de integración multicloud

- Modelo cloud inteligente: servicios core de integración desplegados en nube primaria y contingencia en nube secundaria.
- Portabilidad por contenedores y GitOps (manifiestos declarativos), evitando lock-in en capas críticas.
- Conectividad privada entre nubes y datacenter (VPN/IPSec/Interconnect) con segmentación zero-trust.
- Control de costos FinOps y observabilidad unificada para performance y cumplimiento.

6. Estrategia de API internas y externas + mensajería

- APIs REST externas bajo OpenAPI 3.1 y convenciones Open Finance.
- APIs internas REST/gRPC según necesidad de latencia y tipo de consumo.
- Versionado semántico y deprecación controlada con calendario formal.
- Mensajería por eventos con contratos Avro/JSON Schema versionados y validados en registry.
- Patrones de resiliencia: retry exponencial, DLQ, circuit breaker y timeout perimetral.

7. Gobierno de APIs y microservicios

- API Catalog central, ownership por dominio y ciclo de vida definido (design-build-run-retire).
- Architecture Review Board para cambios mayores y control de deuda técnica.
- Policy-as-code para seguridad, cuotas, headers y compliance en CI/CD.
- KPIs operativos: error rate, p95/p99 latencia, uso por cliente, incidentes y MTTR.
- Matriz RACI para negocio, arquitectura, seguridad, operaciones y cumplimiento.

8. Plan de migración gradual de bajo riesgo

- **Fase 1 (0-3 meses):** fundación de plataforma, API Gateway, IAM y observabilidad.
- **Fase 2 (3-6 meses):** adaptadores legacy, primeros dominios BIAN y eventos no críticos.

- **Fase 3 (6-12 meses):** migración progresiva de funcionalidades a core digital con canary releases.
- **Fase 4 (12+ meses):** optimización, retiro de integraciones duplicadas y cierre de deuda técnica.
- **Estrategia de cutover:** parallel run, feature toggles, reconciliación automática y plan de rollback probado.

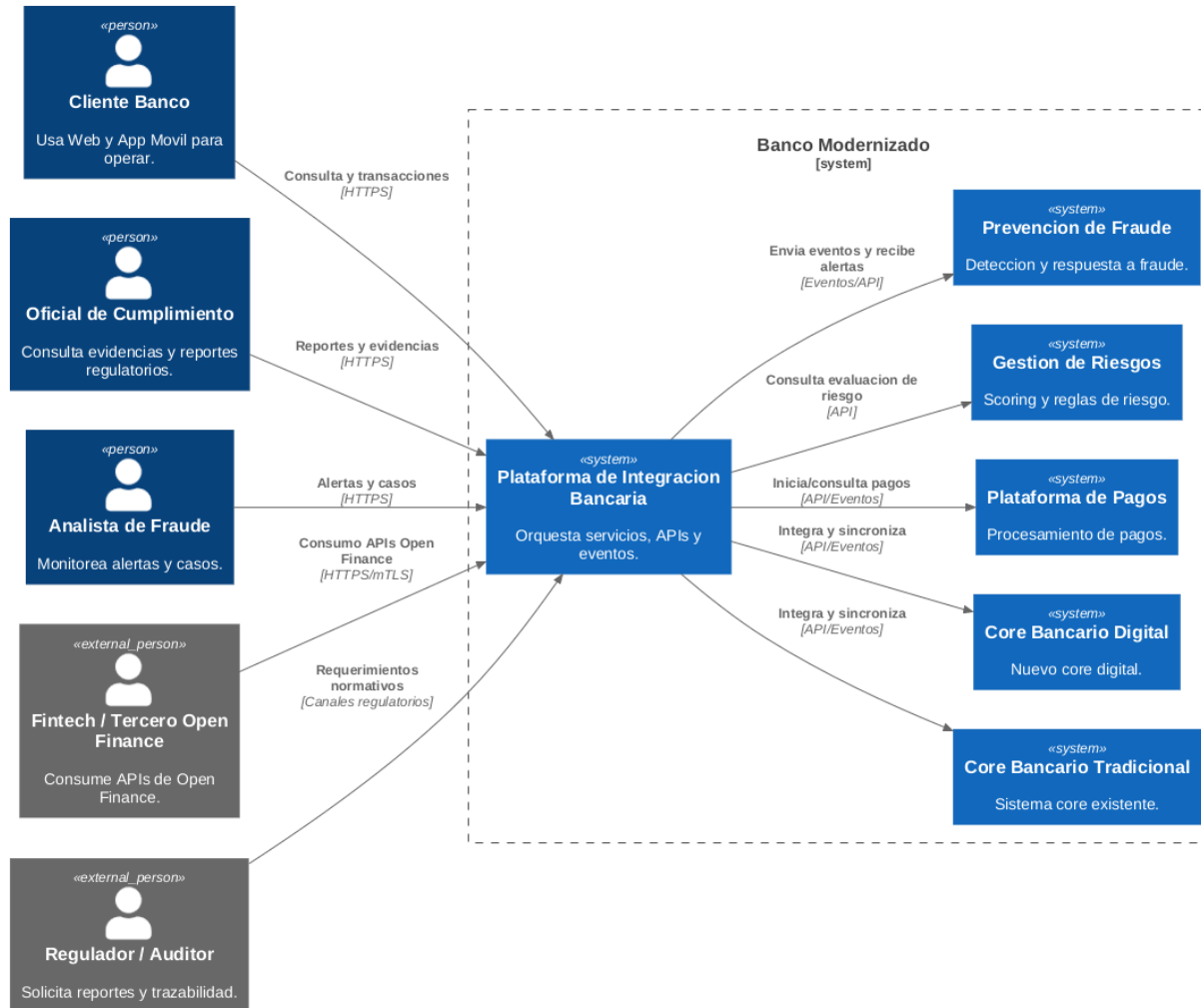
9. Operación, monitoreo y continuidad

- Observabilidad full-stack con trazas distribuidas y correlación por transaction-id.
- Alertamiento por severidad, SLO burn-rate y tableros ejecutivos/operativos.
- Integración con SIEM/SOC para detección temprana y respuesta a incidentes.
- Capacidad de pruebas de caos para validar resiliencia de componentes críticos.

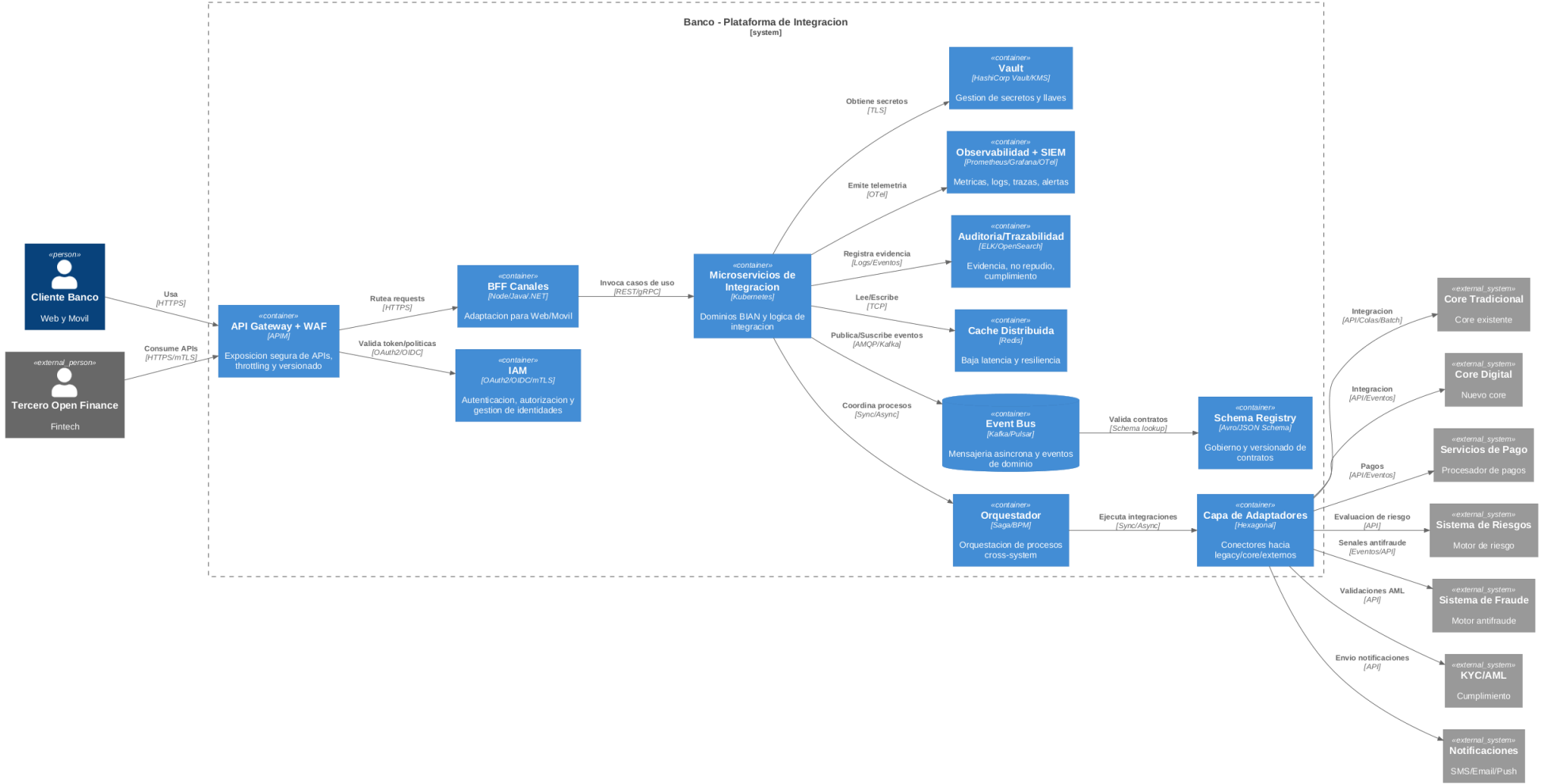
Diagramas C4 (PNG)

A continuacion se incluyen los tres diagramas C4 solicitados.

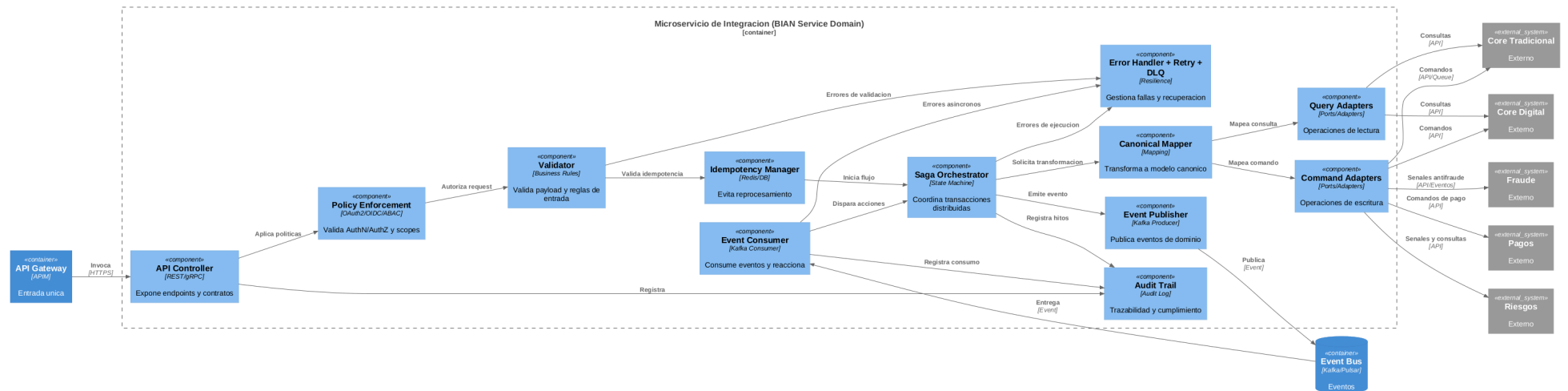
C4 Nivel 1 - Contexto



C4 Nivel 2 - Contenedores



C4 Nivel 3 - Componentes



Conclusiones

- La propuesta cumple requisitos de integracion, seguridad, cumplimiento, HA/DR y monitoreo operacional.
- El uso de BIAN, eventos y gobierno de APIs permite evolucion continua con menor riesgo operativo.
- La migracion gradual y multicloud reduce dependencia tecnologica y asegura continuidad del negocio.

Repositorio:

<https://github.com/AlexBarciaJS/modernizacion-bancaria>